

UNIVERSIDAD UNIANDES

CODEGUARD

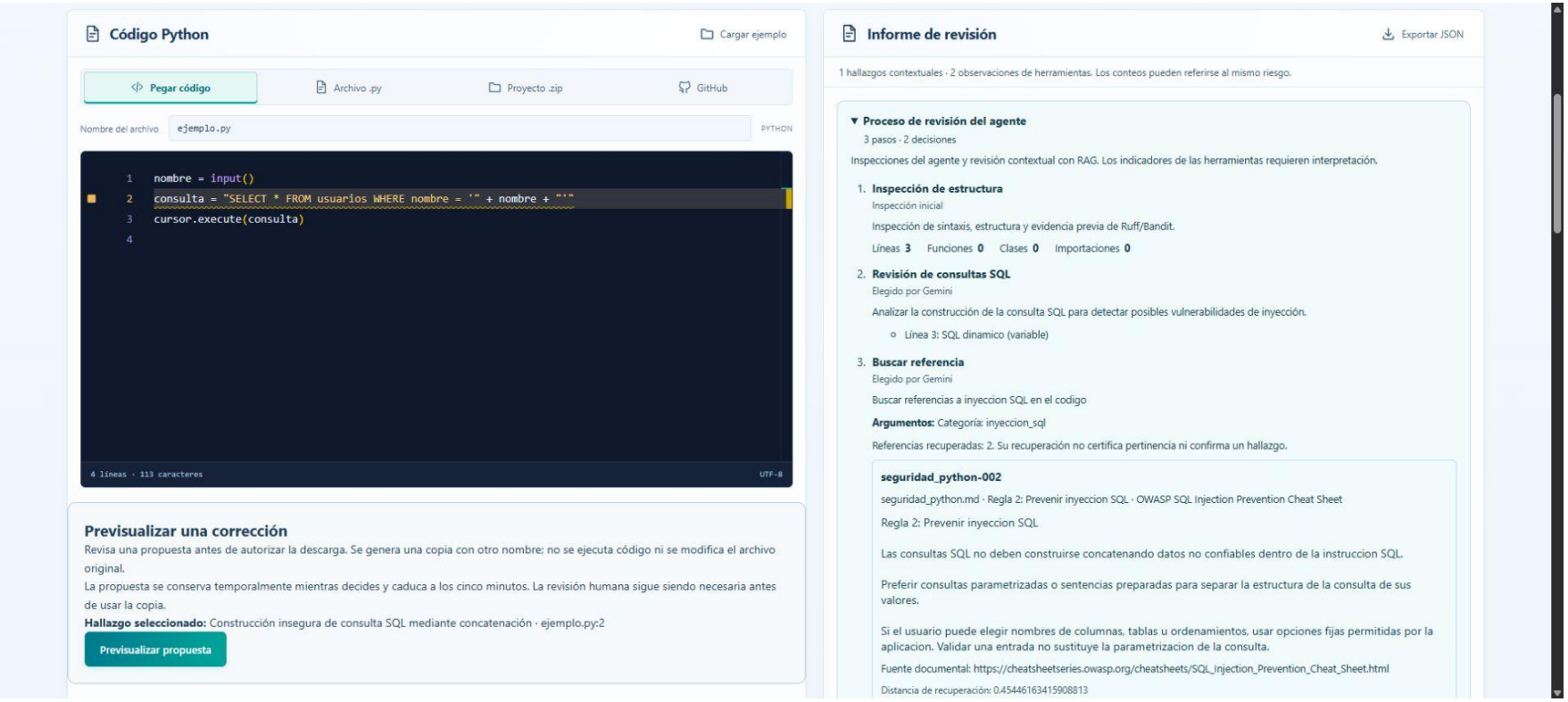
Revisión asistida de código Python

Problema: revisar riesgos y comprobar su evidencia exige tiempo y criterio.

Para desarrolladores, revisores y evaluadores de código.

Ronald Yépez
Klever Alban
Christian Gamboa

Demostración: hallazgo y fuente



Código, ubicación del hallazgo, referencia y proceso del agente.

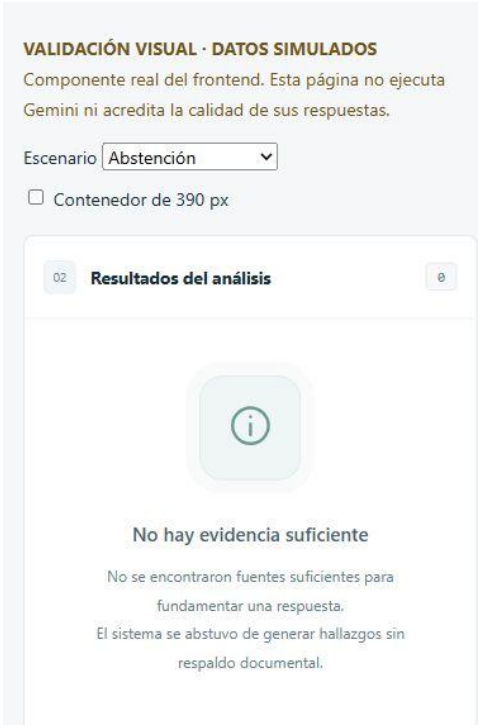
Demostración: abstención



Cuando falta respaldo documental, el sistema comunica la abstención.

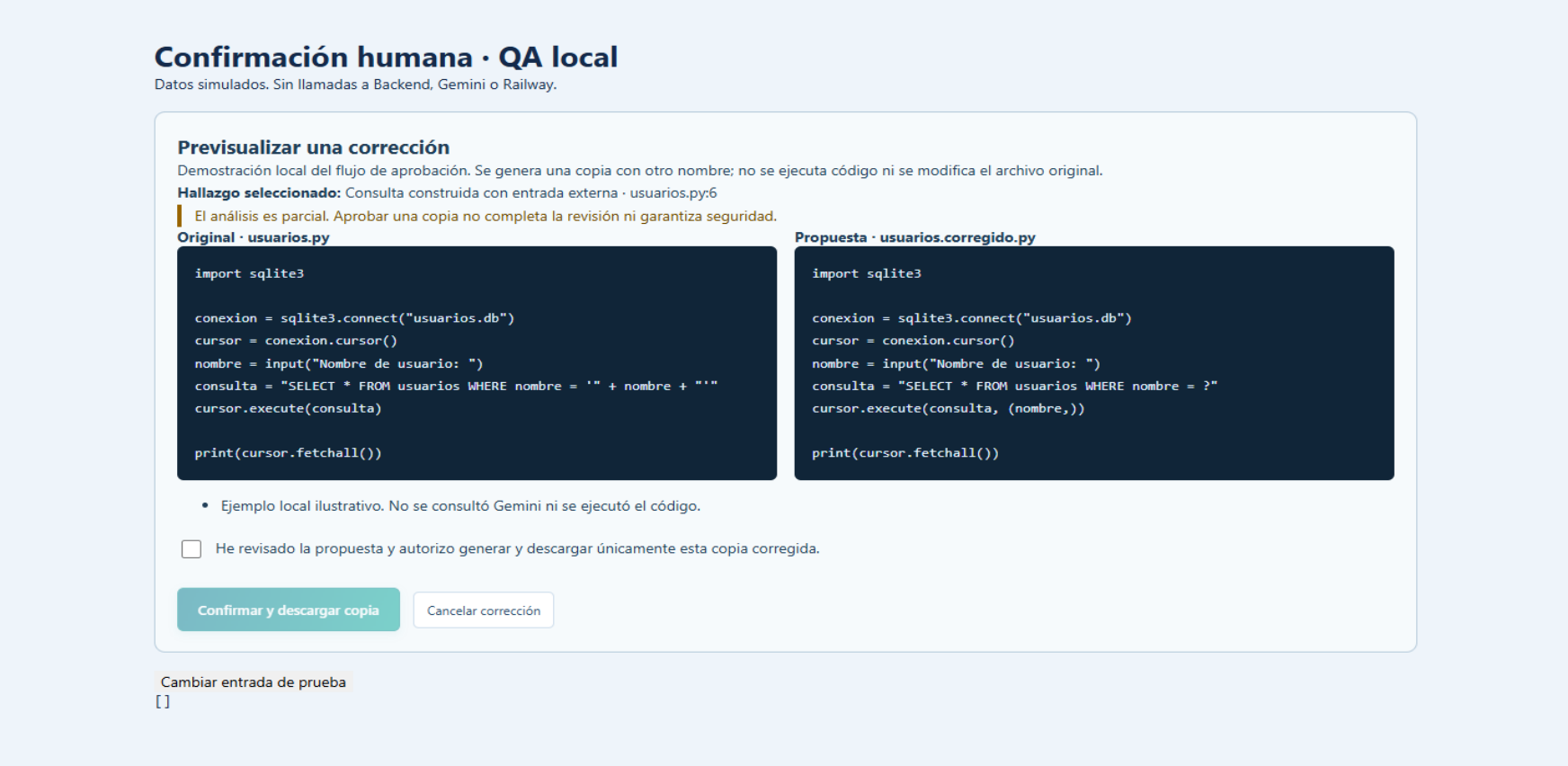
La falta de evidencia no demuestra que el código sea seguro.

La interfaz conserva el motivo y las fuentes consultadas.





Demostración: confirmación humana



Comparar, autorizar y descargar una copia. Cancelar conserva el original.

Presupuesto de proyectos



Revisar archivos y límites antes de autorizar el análisis.

Aprobar inicia el análisis. Rechazar no añade llamadas a Gemini.

Arquitectura del producto

Interfaz y API

- React, TypeScript y Monaco
- FastAPI valida la entrada
- Frontend y API comparten origen

Análisis y conocimiento

- Ruff, Bandit y AST inspeccionan
- ChromaDB recupera fuentes
- Gemini genera la síntesis

Código y .py utilizan el agente integrado. ZIP/GitHub usan la ruta directa por archivo.

Docker y Railway alojan el servicio. ChromaDB y SQLite conservan sus datos.

Agente supervisado y límites

Inspección inicial obligatoria con Ruff/Bandit y AST.

El agente elige herramientas permitidas: contexto, consultas SQL, referencias o finalización.

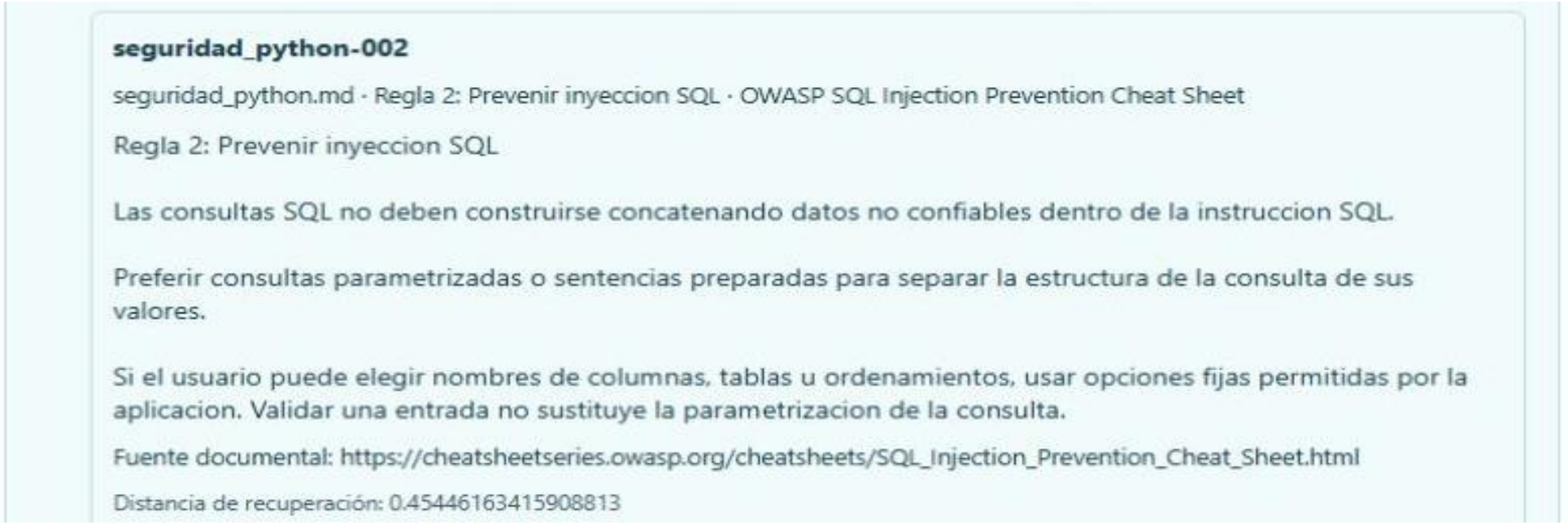
Máximo cuatro pasos. La interfaz principal solicita tres.

Cada resultado alimenta la decisión siguiente y queda en la traza.

Sin shell libre, ejecución del código recibido ni cambios automáticos al original.

Fuentes documentales

Ocho fuentes oficiales de MITRE y OWASP sustentan seis reglas curadas.



El usuario puede consultar la regla, su explicación y el enlace de origen.

Pruebas y pipeline

Comprobación	Resultado documentado
Backend y QA/evaluadores	589 + 80 = 669 pruebas
Frontend	146 aprobadas, lint y build correctos
HTTP con estático	24/24 aprobadas
HTTP sin estático	19/19 aplicables, cinco omitidas
CI de main b6ce96c	Ocho verificaciones aprobadas

Integración HTTP con Gemini/GitHub simulados. Evaluación real por separado.

Evaluación real de veinte casos

Medida	Directa	Agente v2
Informes completos	17/20	14/20
Informes parciales	3/20	6/20
F1 en 13 pares completos	1,00	1,00
Media global	10,34 s	22,62 s
Intentos SDK	21	71

No se demostró mejora de precisión. El F1 corresponde a los trece pares comunes.

Seguridad y control del usuario

El código recibido se inspecciona sin ejecutarlo.

Validación de archivos, ZIP y GitHub. Claves solo en el backend.

Presupuesto: aprobar autoriza el análisis de esa instantánea. Rechazar no añade llamadas a Gemini.

Corrección: aprobar permite descargar una copia revisada. Sesión, hashes y caducidad vinculan la decisión.

Limitaciones y próximos pasos

Lo que conocemos

- Ocho fuentes oficiales y seis reglas curadas.
- Posibles falsos positivos y negativos.
- Fallos y límites del proveedor.

Lo que sigue

- Ampliar corpus y casos de evaluación.
- Repetir comparaciones controladas.
- Mejorar consumo y resiliencia.